

Exercise 1

1. Why is it important to store the JWT secret key in an environment variable instead of hardcoding it?

Answer

Hardcoding the secret key exposes it in the source code. If the code is shared or uploaded to GitHub, anyone can see the key and generate valid JWT tokens. Storing it in an environment variable keeps the secret separate from the application code and improves security.

2. What would happen if the JWT secret key is compromised?

Answer

If the secret key is compromised, an attacker can create fake JWT tokens, impersonate users, gain unauthorized access to protected resources, and potentially perform administrator actions.

3. Why do we use HttpOnly cookies for storing JWT tokens?

Answer

HttpOnly cookies prevent JavaScript from accessing the token, reducing the risk of Cross-Site Scripting (XSS) attacks that could steal authentication tokens.

Exercise 2

1. What security measures should be in place for password reset?

Answer

- Use secure, random reset tokens.
- Set an expiration time (for example, one hour).
- Hash the new password before storing it.
- Invalidate the token after it has been used.
- Verify the user's identity through their registered email.

2. How would you prevent abuse of the forgot password endpoint?

Answer

- Limit the number of reset requests per user or IP address.
 - Use CAPTCHA to prevent automated requests.
 - Avoid revealing whether an email exists in the system.
 - Log suspicious activity.
-

3. Why should reset tokens have an expiration time?

Answer

Expired tokens reduce the chance that a stolen or leaked reset token can be used to change a user's password later.

Exercise 3

1. Why is role-based access control important in a medical application?

Answer

Medical records are highly sensitive. RBAC ensures that users only access information appropriate to their role, protecting patient privacy and complying with healthcare security requirements.

2. How would you handle a patient assigned to multiple doctors?

Answer

Use a many-to-many relationship between patients and doctors through a linking table so one patient can be assigned to multiple doctors and one doctor can manage multiple patients.

3. What happens if a user's role changes?

Answer

Their permissions change immediately. After changing the role, the system should issue a new authentication token or require the user to log in again so the updated permissions are applied.

Exercise 4

1. Why is token blacklisting necessary?

Answer

JWTs remain valid until they expire. Token blacklisting allows the application to invalidate tokens immediately after logout or when they are compromised.

2. What are the trade-offs?

Answer

Advantages:

- Immediate logout
- Better security

Disadvantages:

- Requires storing blacklisted tokens in the database.
 - Every authenticated request must check the blacklist, adding a small amount of overhead.
-

3. How would you handle expired tokens?

Answer

Remove expired tokens from the blacklist automatically using scheduled cleanup tasks or background jobs to keep the database small.

Exercise 5

1. Why is 2FA important in healthcare?

Answer

Healthcare systems store sensitive patient information. Two-factor authentication provides an additional layer of security, making unauthorized access much more difficult.

2. How would you handle a lost 2FA device?

Answer

Provide recovery codes, allow identity verification by an administrator, or use backup authentication methods such as email or SMS verification.

3. What are the trade-offs of 2FA versus longer passwords?

Answer

Longer passwords improve password strength but can still be stolen. Two-factor authentication provides an additional security layer, although it requires extra setup and may slightly reduce convenience.